

Solicitante: I.T.S - Instituto Tecnológico Superior Arias Balparda.

Nombre Fantasía, de la nueva empresa: Lidenskap

Grupo: 3ºMK

Turno: Matutino

Unidad Curricular: Tecnologías de la información

Nombres de los integrantes del grupo: Sofía Prieto, Federico Rodríguez, Gastón Visos, Joaquín Villena.

Fecha de entrega:28/10/2026

Instituto Tecnológico Superior Arias Balparda.
Blvr. José Batlle y Ordóñez 3570 esq. Gral. Flores – Montevideo.

1.1 Sistemas operativos del lado cliente..... 4
Por tanto, la diversidad de dispositivos impacta las estrategias de diseño de software:. 4
1.2 Sistema operativo del lado servidor.....5
Características de AlmaLinux 8.10 Minimal..... 5
Característica..... 5
Descripción.....5
1.3 Especificaciones de hardware virtualizado..... 6
Componente.....6
Requisito Mínimo.....6
Recomendado (Producción/Servicios)..... 6
1. Capacidad de Procesamiento (1 vCPU)..... 6
2. Memoria Volátil (4 GB de RAM)..... 7
3. Almacenamiento Virtualizado (32 GB HDD - Thin Provisioning).....7
4. Eficiencia por la Falta de Entorno Gráfico (GUI)..... 7
2.1 Base conceptual.....8
2.2 Usuarios del sistema operativo definidos para el servidor..... 8
Usuario..... 8
Tipo.....8
Propósito..... 8
Grupo..... 8
Privilegios..... 8
Shell..... 8
Ninguna cuenta humana comparte credenciales y el sudo se otorga por grupo (sgdm_admins) y no por usuario, para poder editarlo o revocar de forma centralizada; y la aplicación corre bajo svc_sgdm, una cuenta que no puede iniciar sesión interactiva..... 8
1.Política de respaldos..... 9
1.1 Tipos de respaldos a utilizar.....9
Elección y justificación para la app:.....9
Almacenamiento de los respaldos:.....9
1.2 Cronograma de respaldo definido..... 11
2. Script de respaldos y automatización (cron).....12
2.1 Qué hace el script.....12
2.2 Automatización con cron..... 12
2.3 Copia offsite a Google Drive.....12
3. Sistema de monitoreo (Zabbix, Grafana, etc.).....13
3.1 Justificación: por qué Netdata y no Zabbix o Grafana.....13
3.2 Instalación..... 13
3.3 Seguridad: por qué no se abre un puerto nuevo..... 14

3.4 Qué se monitorea..... 14
3.5 Mantenimiento..... 14
Políticas de seguridad..... 15
Introducción..... 15
A01 Control de acceso roto..... 15
A02 Configuración de seguridad incorrecta..... 15
A03 Fallas en la cadena de suministro de software..... 16
A04 Fallas criptográficas..... 16
A05 Inyección..... 16
A06 Diseño inseguro..... 16
A07 Fallas de autenticación..... 17
A08 Fallas de integridad de software o datos..... 17
A09 Fallas de registro y alertas..... 17
A10 — Manejo incorrecto de condiciones excepcionales..... 18
Cumplimiento y revisión.....18

ESTUDIO DE SISTEMAS OPERATIVOS CLIENTE Y SERVIDOR

1.1 Sistemas operativos del lado cliente

El SGDM es una aplicación web, por lo que el sistema operativo de los usuarios finales está fuera del alcance del equipo de desarrollo y del organizador del torneo. Los distintos perfiles de usuario (administrador general, organizador de torneo, participante y usuario público) conectan con la plataforma a través de diversos dispositivos y sistemas operativos, algunos de los cuales son Windows 10/11 y distribuciones de Linux para ordenadores de instituciones educativas y clubes, macOS para ordenadores personales y Android e iOS para el acceso móvil. Se destaca que la disponibilidad de Android es mayor en el mercado local.

Por tanto, la diversidad de dispositivos impacta las estrategias de diseño de software:

• No influye mucho qué sistema operativo se utilice sino cuál navegador se use, ya que cada motor de renderizado (Blink en Chrome/Edge, Gecko en Firefox, WebKit en Safari) aplica sus interpretaciones diversificadas de CSS y JavaScript.

• La app debe implementarse basándose en el principio Mobile First, puesto que gran parte de la base de usuarios se acercará desde dispositivos móviles con Android o iOS, tal como se especifica en el requisito de Programación Full Stack.

• No puede asumirse que el usuario cuente con privilegios administrativos sobre su propio equipo (por ejemplo, en salas de informática compartidas), lo que refuerza la decisión de no requerir instalación de software adicional ni complementos nativos.

• Debe contemplarse la accesibilidad para usuarios sin conocimientos técnicos, así como conexiones de baja velocidad y navegadores desactualizados, mediante interfaces livianas y mensajes de error claros

1.2 Sistema operativo del lado servidor

El sistema operativo del servidor fue seleccionado por la institución, mediante la asignación de una máquina virtual dentro de la plataforma de virtualización Proxmox. Por lo que es nuestro trabajo investigar detalladamente las características, ventajas y limitaciones del sistema operativo entregado, con el fin de adecuar los requerimientos del proyecto SGDM e identificar los pasos técnicos necesarios para su administración.

El sistema operativo asignado es AlmaLinux 8.10 ("Cerulean Leopard"), en su variante minimal, preconfigurado con las aplicaciones base necesarias para el funcionamiento del proyecto: Apache 2.4, PHP 8.3 y MariaDB 10.11.

Características de AlmaLinux 8.10 Minimal

Característica	Descripción
Origen y familia	Es una distribución de Linux binariamente compatible con Red Hat Enterprise Linux (RHEL). Surgió como una alternativa comunitaria y gratuita tras el cambio de modelo de CentOS.
Licenciamiento	Es de código abierto (Open Source) y gratuita. No requiere pagos de suscripción ni licencias para su uso en producción o desarrollo.
Gestor de paquetes	Utiliza DNF (Dandified YUM) para la gestión, instalación y actualización de software, manejando paquetes en formato .rpm.
Ciclo de soporte	La rama 8.x de AlmaLinux tiene soporte oficial y recibirá actualizaciones de seguridad hasta mayo de 2029, asegurando la vigencia de la plataforma a largo plazo.
Sin Entorno Gráfico	No cuenta con interfaz visual de usuario (GUI). Toda la administración se realiza estrictamente por línea de comandos (CLI), habitualmente a través de conexiones SSH.
Instalación Limpia (Barebone)	Solo incluye los paquetes importantes para que el sistema base funcione. Herramientas cotidianas como git, unzip o comandos de diagnóstico de red no vienen preinstaladas y se deben añadir manualmente a través de DNF.
Firewalld	Incorpora firewalld por defecto para gestionar el filtrado de puertos de red mediante zonas y servicios dinámicos (en lugar de usar iptables de manera directa).

1.3 Especificaciones de hardware virtualizado

Componente	Requisito Mínimo	Recomendado (Producción/Servicios)
Arquitectura	x86_64 (Intel/AMD de 64 bits)	x86_64 o AArch64 (ARM64)
Procesador (vCPU)	1 núcleo físico / virtual	2 núcleos o más
Memoria RAM	1.5 GB RAM (Límite para instalador gráfico/interactivo)	4 GB RAM o superior
Almacenamiento (Disco)	10 GB de espacio libre	20 GB o más (según el volumen de BD)
Tarjeta de Red (NIC)	1 Adaptador de red estándar	1 Adaptador Gigabit Ethernet (VirtIO)

En un entorno académico con un uso limitado de recursos (destinado únicamente a pruebas del equipo de desarrollo y evaluación del cuerpo docente, sin tráfico de producción en tiempo real), los recursos de hardware asignados en el hipervisor Proxmox son, desde un punto de vista técnico, adecuados para soportar la stack LAMP dada. Sin embargo, la sostenibilidad del sistema a medio plazo está condicionada directamente a una adecuada optimización de los servicios, sustentada en los siguientes elementos de hardware virtual:

1. Capacidad de Procesamiento (1 vCPU)

suficiencia: Un solo núcleo de CPU virtual es apropiado para gestionar las solicitudes HTTP simultáneas del equipo de desarrollo (de 3 a 4 usuarios al mismo tiempo) y para ejecutar scripts de automatización en Bash.

Estrategia de mitigación: Dado que no se dispone de procesamiento paralelo real proporcionado por hardware, es crucial evitar procesos intensivos en segundo plano. La configuración de MariaDB y PHP-FPM debe ser adaptada limitando el número máximo de hilos de trabajo y conexiones concurrentes para evitar cuellos de botella que incrementen la carga del CPU.

2. Memoria Volátil (4 GB de RAM)

Suficiencia: Esta cantidad de memoria se considera amplia para un sistema operacional basado en AlmaLinux 8.10 Minimal. Al iniciar el sistema operativo sin interfaz gráfica, el consumo base en reposo no supera los 400 MB (menos del 10% de la memoria física disponible). Esto proporciona más de 3.5 GB libres que pueden ser distribuidos entre el servidor web Apache, el intérprete PHP y el motor MariaDB.

Estrategia de mitigación: Es necesario ajustar las variables de configuración del motor de base de datos MariaDB (por ejemplo, innodb_buffer_pool_size y key_buffer_size) para operar en entornos limitados, evitando los valores predeterminados que están diseñados para servidores dedicados con mayor capacidad.

3. Almacenamiento Virtualizado (32 GB HDD - Thin Provisioning)

Suficiencia: La asignación de 32 GB de espacio virtualizado es más que suficiente para almacenar el sistema operativo base (~3 GB), el código fuente del proyecto, el esquema de base de datos con los registros de prueba requeridos en la materia de Programación Full Stack (mínimo 50 registros por entidad) y los logs generados.

Estrategia de mitigación: Al implementar Thin Provisioning (aprovisionamiento dinámico), el disco físico del servidor Proxmox solo utilizará el espacio efectivamente consumido en la máquina virtual. Sin embargo, para prevenir el agotamiento del almacenamiento disponible, es fundamental establecer políticas estrictas de rotación de logs (ajustando logrotate para Apache y el sistema operativo) y adoptar una rutina de limpieza para evitar la acumulación de respaldos históricos localmente en la máquina virtual, aspecto que se abordará en la próxima entrega.

4. Eficiencia por la Falta de Entorno Gráfico (GUI)

Suficiencia: La instalación de la variante Minimal es el aspecto determinante que asegura la adecuación del hardware disponible. Al no cargar un servidor gráfico (como X11 o Wayland) ni un entorno de escritorio (como GNOME o XFCE), se elimina el consumo innecesario de recursos de procesamiento y gráficos virtualizados.

Estrategia de mitigación: El equipo de desarrollo se compromete a que toda la gestión del servidor se realice exclusivamente de forma remota a través del protocolo SSH o mediante la consola integrada de Proxmox, optimizando así el rendimiento efectivo del hardware.

ANÁLISIS DE USUARIOS DE SISTEMA

Es esencial diferenciar este estudio de los roles funcionales de la aplicación web que se encuentran definidos en Ingeniería de Software (administrador general, organizador de torneo, participante y usuario público), los cuales forman parte de la lógica empresarial del SGDM. Este apartado se centra exclusivamente en las cuentas de usuario del sistema operativo Linux donde se ejecuta la aplicación.

2.1 Base conceptual

En los sistemas operativos GNU/Linux, cada proceso opera bajo la identidad de un usuario determinado, quien a su vez tiene permisos establecidos a través de identificadores UID/GID respecto a archivos, directorios y recursos del sistema. El principio fundamental que guía el diseño de usuarios en el servidor es el de privilegio mínimo: cada persona o proceso debe tener solamente los permisos necesarios para llevar a cabo sus tareas, reduciendo así el riesgo en caso de un posible incidente de seguridad. Este enfoque se relaciona de manera directa con los temas tratados en ciberseguridad.

2.2 Usuarios del sistema operativo definidos para el servidor

Usuario	Tipo	Propósito	Grupo	Privilegios	Shell
sprieto	Persona	Cuenta de administración del servidor para Sofía Prieto	sgdm_admins, sgdm_devs	sudo	/bin/bash
gvisos	Persona	Cuenta de administración del servidor para Gastón Visos	sgdm_admins, sgdm_devs	sudo	/bin/bash
frodriguez	Persona	Cuenta de administración del servidor para Federico Rodríguez	sgdm_admins, sgdm_devs	sudo	/bin/bash
jvillena	Persona	Cuenta de administración del servidor para Joaquín Villena	sgdm_admins, sgdm_devs	sudo	/bin/bash
svc_sgdm	De servicio	Dueño de los archivos y procesos de la aplicación web	sgdm_devs	Sin sudo, sin acceso interactivo	/sbin/nologin

Ninguna cuenta humana comparte credenciales y el sudo se otorga por grupo (sgdm_admins) y no por usuario, para poder editarlo o revocar de forma centralizada; y la aplicación corre bajo svc_sgdm, una cuenta que no puede iniciar sesión interactiva.

Segunda entrega ADMINISTRACIÓN DE SISTEMAS OPERATIVOS

1.Política de respaldos

1.1 Tipos de respaldos a utilizar

Para garantizar la integridad de la información de SGDM las políticas de respaldo aplicadas son diseñadas considerando las limitaciones de hardware. Con estas mismas garantizamos no solo la recuperación de la información, sino hacerlo sin comprometer el rendimiento del servidor durante su ejecución.

Elección y justificación para la app:

Qué se respalda concretamente

- Base de datos MariaDB completa (esquema SGDM con las más de 12 entidades del modelo: Usuario, Torneo, Participante, Resultado, etc.)
- Directorio de la aplicación web (código PHP, assets)
- Configuración de Apache, PHP y firewalld
- No se incluyen logs del sistema en el respaldo

Quedan fuera del alcance del respaldo los archivos de log del sistema y de la aplicación, dado que su gestión corresponde a una política de rotación independiente (logrotate) y el almacenamiento de las copias, se define una copia local en el propio servidor para restauraciones rápidas ante errores operativos comunes, y una copia secundaria fuera del servidor, resguardada en un equipo distinto al de producción. Esta duplicación responde al requerimiento de reducir al mínimo la posibilidad de pérdida de información ante una eventual falla de hardware o de red local.

Almacenamiento de los respaldos:

Utilizamos una copia de los respaldos que se comprime y se almacena localmente en el servidor para garantizar una restauración inmediata en caso de que se borre accidentalmente. También, el sistema debe transferir una copia a un entorno remoto u externo (offsite), garantizando el aguante a desastres en caso de que la máquina virtual de Proxmox sufra daños.

Tipo de Respaldo	Descripción	Ventaja	Desventaja
Completo (Full)	Copia total de todos los archivos, bases de datos y configuraciones del servidor en un momento dado.	Restauración rápida y sencilla, ya que todo está en un solo archivo o conjunto.	Consume mucho espacio de almacenamiento y tiempo de procesamiento (CPU/Disco).
Incremental	Copia únicamente de los datos que han sido modificados desde el último respaldo (ya sea completo o incremental).	Muy rápido de ejecutar y ocupa el mínimo espacio posible.	La restauración es más lenta, requiere el respaldo completo y todos los incrementales posteriores.
Diferencial	Copia de todos los datos modificados desde el último respaldo completo.	Restauración más rápida que el incremental (solo requiere el completo y el último diferencial).	A medida que pasan los días, el tamaño del respaldo crece y consume más recursos que el incremental.
Completo de configuración y código	Directorio de la aplicación web, configuración de Apache, PHP y firewalld.	Tiene una recuperación rápida del entorno del trabajo, reduce el tiempo de inactividad.	No protege los datos dinámicos, si solo se respalda el código y la configuración se podría perder información que cambia constantemente.

1.2 Cronograma de respaldo definido

Frecuencia de cada tipo de respaldo (ej: incremental diario a las X hora, completo semanal).

Horario elegido y justificación (ej: fuera del horario de uso del equipo de desarrollo, aprovechando que son solo 3-4 usuarios simultáneos según ya documentaron).

Retención: cuántas copias se conservan y durante cuánto tiempo antes de eliminarlas (relacionado con el punto de "políticas estrictas de rotación" que ya mencionaron en la primera entrega sobre logs — es el mismo principio aplicado a backups).

Quién es responsable de verificar que los respaldos se ejecutaron correctamente (rol dentro del equipo, no del sistema).

Respaldo	**Frecuencia**	**Horario**	**Retención**
Base de datos	Diario	03:00 Am	7 copias (1 semana
Configuración y código de la aplicación	Semanal	Domingo, 03:30 Am	4 copias (1 mes)

El horario se fija fuera de la franja de uso habitual del equipo, evitando así cualquier problema por CPU entre las tareas de respaldo y la operación normal del sistema, y se implementa una rotación de backups para no agotar los 32 GB del disco duro. Superado el número de copias definido para cada tipo, el respaldo más antiguo se elimina automáticamente, evitando que la acumulación del historial afecte el espacio disponible del disco virtualizado.

Cualquier miembro del grupo sgdm_admins será el responsable semanal de verificar los logs de respaldo y realizar al menos una prueba de restauración mensual en un entorno controlado para asegurar que los archivos no estén corruptos.

2. Script de respaldos y automatización (cron)

2.1 Qué hace el script

El script respaldo_sgdm.sh automatiza los dos tipos de respaldo de la sección anterior, ejecutables por separado o en conjunto (acción "todo"):

bd: dump de la base de datos MariaDB completa (mariadb-dump, con reserva a mysqldump si no está disponible), comprimido con gzip.

app: empaquetado en tar.gz del directorio de la aplicación (/var/www/html) más la configuración de Apache, PHP y firewalld, excluyendo directorios de logs.

Cada respaldo queda en /var/backups/sgdm/bd/ o /var/backups/sgdm/app/ con fecha y hora en el nombre de archivo, y el script aplica la rotación automática de la tabla anterior (elimina los respaldos más antiguos por encima de la retención configurada), así el disco de 32GB de la VM no se llena con historial acumulado.

2.2 Automatización con cron

El comando sudo ./respaldo_sgdm.sh instalar-cron genera /etc/cron.d/sgdm_respaldos con el cronograma ya definido: base de datos todos los días a las 03:00, código y configuración los domingos a las 03:30. Ambos horarios caen fuera del uso habitual del entorno de desarrollo, evitando competir por CPU con la operación normal del sistema. Toda la actividad (éxito, error, rotación) queda registrada en /var/log/sgdm_respaldos.log.

2.3 Copia offsite a Google Drive

Además de la copia local, el script envía cada respaldo a Google Drive mediante rclone, como resguardo fuera del servidor ante una eventual falla de la VM de Proxmox (no hay presupuesto para un segundo servidor propio dedicado a esto).

Ese envío requiere un paso de configuración único e interactivo directamente en el servidor real: rclone config, que abre un login de Google y guarda la conexión bajo el nombre gdrive. Al ser una autenticación OAuth, no se puede automatizar sin intervención humana. Hasta que ese paso se complete y se active OFFSITE_HABILITADO="true" en el script, los respaldos quedan solo con la copia local (con su rotación ya funcionando de punta a punta).

3. Sistema de monitoreo (Zabbix, Grafana, etc.)

Se instaló Netdata en el servidor de SGDM para contar con monitoreo en tiempo real de CPU, RAM, disco, red y procesos, además de métricas específicas de MariaDB y Apache. La instalación y configuración están automatizadas en el script monitoreo_sgdm.sh; a continuación se explica qué hace ese script, por qué se tomaron esas decisiones, y cómo replicar los pasos a mano si hiciera falta.

3.1 Justificación: por qué Netdata y no Zabbix o Grafana

El servidor es una única VM AlmaLinux 8.10 Minimal con 1 vCPU, 4 GB de RAM y 32 GB de disco thin-provisioned, ya usados por Apache, PHP y MariaDB para la aplicación. No hay presupuesto para un segundo servidor dedicado exclusivamente a monitoreo, así que la herramienta elegida tenía que entrar en ese margen de recursos ya ajustado.

Herramienta	Qué requiere	Por qué no se usó / se usó
Zabbix	Base de datos propia, frontend PHP y un proceso server corriendo todo el tiempo.	Demasiado pesado para una VM que ya está justa de recursos.
Grafana + Prometheus	Dos servicios adicionales corriendo en simultáneo.	Es el combo más pesado de los tres.
Netdata	Un único agente con dashboard web incorporado, sin base de datos propia ni proceso servidor separado.	Elegido: es la opción que mejor entra en el presupuesto de recursos ya ajustado de esta VM.

3.2 Instalación

EPEL no empaqueta netdata para AlmaLinux/RHEL 8, así que no se pudo instalar directo desde un repositorio ya confiable del sistema (dnf install netdata). Se usó el instalador oficial de Netdata (kickstart.sh), evitando un "curl | bash" ciego, ejecutando en el servidor:

sudo ./monitoreo_sgdm.sh instalar

Internamente, esa acción:

Descarga el instalador a un archivo local, en vez de ejecutarlo directo desde la red.

Registra el hash SHA-256 del archivo descargado en el log del servidor, para poder auditar más adelante exactamente qué se ejecutó.

Recién ahí lo ejecuta, con las banderas --non-interactive --disable-telemetry --stable-channel.

El instalador detecta la distribución y arma los paquetes nativos automáticamente, incluyendo EPEL como dependencia si hace falta.

3.3 Seguridad: por qué no se abre un puerto nuevo

El firewall del servidor (firewalld) solo deja pasar los puertos 22, 80 y 443 entrantes. El dashboard de Netdata usa por defecto el puerto 19999, que no está en esa lista.

En vez de abrir un puerto nuevo en firewalld o poner un reverse proxy en Apache (que expondría el dashboard públicamente si no se protege bien), se configuró Netdata para escuchar solo en 127.0.0.1 (loopback). El único modo de llegar al dashboard es mediante un túnel SSH sobre la conexión que ya existe:

ssh -L 19999:localhost:19999 usuario@<IP del servidor>

Con el túnel abierto, se accede a http://localhost:19999 desde el navegador local.

3.4 Qué se monitorea

Sistema operativo (activo apenas se instala): CPU, RAM, swap, disco, red, procesos y carga del sistema — lo necesario para vigilar que la única vCPU y los 4 GB de RAM del servidor no se saturen.

MariaDB (vía sudo ./monitoreo_sgdm.sh collectors-mysql): crea un usuario netdata_monitor@localhost con permisos únicamente de USAGE, PROCESS y REPLICATION CLIENT, sin acceso a ninguna tabla ni base de datos de la aplicación.

Apache (vía sudo ./monitoreo_sgdm.sh collectors-apache): habilita mod_status (ya viene compilado en httpd) restringido a solo acceso desde localhost, y apunta el collector de Netdata a http://127.0.0.1/server-status?auto. No se abre ningún puerto nuevo.

3.5 Mantenimiento

El log de instalación y configuración queda en /var/log/sgdm_monitoreo.log. El estado del servicio se puede revisar con "sudo ./monitoreo_sgdm.sh estado" o "systemctl status netdata". Para uso interactivo puntual (arrancar, parar o reiniciar Netdata a mano), gestionar_servicio.sh también sirve, ingresando "netdata" como nombre de servicio.

Tercera entrega ADMINISTRACIÓN DE SISTEMAS OPERATIVOS

Políticas de seguridad

Introducción

Este documento define las políticas de seguridad que protegen la base de datos del SGDM, tomando como marco el OWASP Top 10:2025, la lista de los diez riesgos más críticos en aplicaciones web.

Alcance. La base de datos sgdm corre en MariaDB 11.4 dentro de un contenedor Docker, en la máquina virtual Proxmox de la UTU. Tiene 16 tablas y 2 vistas, y la aplicación PHP (MVC) accede a ella mediante PDO. Los datos más sensibles son los de la tabla usuario (email y contraseña), participante (fecha de nacimiento) y los resultados de los torneos (resultado, tabla_posiciones), cuya integridad define quién gana una competencia.

A01 Control de acceso roto

Política: cada usuario, de la aplicación o de la base, accede solo a lo que su función necesita (principio de mínimo privilegio).

- En la base existen tres usuarios con permisos separados: el administrador (ALL PRIVILEGES, solo mantenimiento y respaldos), el usuario de la aplicación (SELECT, INSERT, UPDATE, DELETE, sin permisos para crear o borrar tablas) y el usuario de consulta pública (solo SELECT sobre las tablas de torneos, sin acceso a usuario ni auditoria_registro).
- En la aplicación, los cinco roles de la tabla rol (ADMIN, ORGANIZADOR, ARBITRO, PARTICIPANTE, PUBLICO) se verifican en el servidor con Auth::requireRole(), que corta con error 401 o 403. Nunca se confía en el rol guardado en el navegador.
- Un organizador solo puede modificar los torneos donde figura como id_usuario_organizador, y solo un árbitro o administrador puede marcar un resultado como validado.

A02 Configuración de seguridad incorrecta

Política: ningún servicio queda expuesto ni con valores por defecto en el servidor de producción.

- El puerto 3306 de MariaDB no se publica hacia afuera: hoy docker-compose.yml lo expone, y debe eliminarse para que solo el contenedor web llegue a la base por la red interna de Docker.
- Las contraseñas de root y de los tres usuarios se cambian antes del despliegue y viven en el archivo .env, que no se sube al repositorio.
- PHP no muestra errores en pantalla (display_errors = Off) y Apache no lista directorios

A03 Fallas en la cadena de suministro de software

Política: solo se usan imágenes y componentes de fuentes oficiales, con versión fija.

- Se usan las imágenes oficiales mariadb:11.4 y php:8.3-apache, con versión declarada y no latest.
- Las imágenes se actualizan periódicamente para recibir parches de seguridad, y se revisa cualquier librería externa antes de agregarla.

A04 Fallas criptográficas

Política: ninguna contraseña se guarda en texto plano y los datos viajan cifrados.

- Las contraseñas se guardan con password_hash() (bcrypt) en la columna usuario.password, de 255 caracteres, y se comprueban con password_verify().
- El acceso al sistema se hace por HTTPS para que credenciales y cookies de sesión no viajen en claro.
- Los respaldos de la base se guardan con acceso restringido, porque contienen emails y fechas de nacimiento.

A05 Inyección

Política: ningún dato del usuario se concatena dentro de una consulta SQL.

- Todas las consultas usan sentencias preparadas de PDO (prepare() con parámetros) y la conexión desactiva la emulación (ATTR_EMULATE_PREPARES = false), de modo que MariaDB separa el código SQL de los datos.
- Aunque una inyección lograra pasar, el usuario de la aplicación no puede ejecutar DROP ni ALTER, lo que limita el daño.
- Los datos que se muestran en pantalla se escapan para evitar XSS

A06 Diseño inseguro

Política: las reglas del negocio se imponen también desde la propia base de datos.

- Las restricciones del esquema impiden datos inválidos: CHECK evita que un competidor se enfrente a sí mismo, UNIQUE impide inscribirse dos veces al mismo torneo, y los ENUM limitan los estados posibles.
- El ganador y los puntos no se almacenan: se calculan en vista_resultado y vista_tabla_posiciones, así que no pueden alterarse a mano sin cambiar las puntuaciones.

A07 Fallas de autenticación

Política: las cuentas se protegen contra robo de sesión y ataques de fuerza bruta.

- Contraseñas: mínimo 12 caracteres, el mismo criterio fijado en la segunda entrega de Ciberseguridad. Hoy register.php y usuarios.php exigen 8, por lo que debe subirse a 12.
- Fuerza bruta: máximo 5 intentos fallidos por IP en 15 minutos; al superarlos se bloquea el acceso temporalmente. En el servidor, fail2ban refuerza este bloqueo a nivel de red.
- Mensajes de error: el login responde siempre "Correo o contraseña incorrectos", sin indicar cuál de los dos falló, para no revelar qué emails están registrados. Esto ya está implementado.
- Sesión: al iniciar sesión se regenera el identificador (session_regenerate_id(true)) para evitar la fijación de sesión, y al cerrarla se destruye en el servidor.
- Estado de la cuenta: una cuenta suspendido o inactivo (columna usuario.estado) no puede iniciar sesión. También está implementado

A08 Fallas de integridad de software o datos

Política: los datos críticos de una competencia no cambian sin control.

- Un resultado cargado queda con validado = FALSE hasta que un árbitro o administrador lo confirma; después de validado no se edita sin dejar registro.
- Las claves foráneas con ON DELETE CASCADE o SET NULL mantienen la integridad referencial al borrar registros.
- Se hacen respaldos periódicos con el script respaldo_sgdm.sh (basado en mariadb-dump) y se prueba que se puedan restaurar.

A09 Fallas de registro y alertas

Política: toda acción sensible queda registrada y se revisa.

- La tabla auditoria_registro guarda quién hizo la acción, qué hizo, sobre qué tabla, cuándo y desde qué IP (ip_origen). Debe escribirse en cada login, alta o baja de usuario, carga y validación de resultados.
- El registro se conserva aunque se borre el usuario (ON DELETE SET NULL), y el usuario de consulta pública no puede leerlo.
- El script de monitoreo del servidor revisa estos registros y los logs de MariaDB para detectar intentos fallidos repetidos.

A10 — Manejo incorrecto de condiciones excepcionales

Política: ante un error, el sistema falla de forma segura y no revela información interna.

- PDO trabaja en modo excepción (ERRMODE_EXCEPTION): los errores se capturan, se registran en el servidor y al usuario solo se le muestra un mensaje genérico, nunca el texto SQL ni la estructura de las tablas.
- Las operaciones que tocan varias tablas (por ejemplo, cargar un resultado y actualizar posiciones) se ejecutan dentro de una transacción, y si algo falla se revierte todo.

Cumplimiento y revisión

Estas políticas aplican a todo el equipo de Lidenskap y a cualquier persona con acceso al servidor o a la base de datos del SGDM. El administrador de la base es responsable de los usuarios, permisos y respaldos; los desarrolladores, de que el código use consultas preparadas, valide roles en el servidor y registre las acciones sensibles.

Las políticas se revisan en cada entrega del proyecto o ante cualquier cambio en la arquitectura, y se contrastan con la edición vigente del OWASP Top 10.